

Security Incident Report

SSH Brute-Force Authentication Attack — Endpoint-01

Prepared by: [Your Name]
Environment: Self-hosted SOC lab — Wazuh 4.9.2 (SIEM/EDR) monitoring an Ubuntu 26.04 endpoint
Detection Platform: Wazuh Manager (Wazuh-Manager, 10.0.2.3) — analogous EDR/SIEM workflow to SentinelOne
Report Date: August 28, 2026
Classification: Simulated attack — controlled lab environment

1. Executive Summary

On August 27–28, 2026, a simulated SSH brute-force attack was executed against a monitored Ubuntu endpoint (Endpoint-01) within a self-built SOC lab environment. The lab consists of a Wazuh manager performing centralized log analysis and a Wazuh agent installed on the monitored endpoint, mirroring the EDR-based detection and response workflow used by managed SOC platforms such as SentinelOne.

The attack generated 99 correlated security events, escalating from individual failed authentication attempts to a high-severity, correlated brute-force detection (Rule 5712, Level 10). The detection was validated against MITRE ATT&CK technique T1110 (Brute Force) and mapped to GDPR, HIPAA, and TSC compliance controls. A secondary gap was identified in File Integrity Monitoring (FIM) coverage, and an active response (automated IP blocking) control was configured and partially validated.

2. Incident Timeline

Time (UTC)	Event	Rule ID / Level
23:33:19	First failed SSH login attempt using non-existent user 'fakeuser'	5710 / 5
23:33:26 – 23:34:56	Repeated failed login attempts from same source (loopback)	5710, 5503, 2502 / 5–10
23:34:56.638	Correlated brute-force detection triggered — 8 failures within 120s window	5712 / 10
23:35:03 – 23:35:05	Continued failed attempts logged post-detection	5710, 5503 / 5
~00:07 (2nd test)	Second brute-force simulation run to validate active response	5712 / 10
Ongoing	File integrity checks (syscheck) queried for /etc and /root test files — no alerts generated	N/A

3. Primary Finding: SSH Brute-Force Detection (Rule 5712)

3.1 Detection Details

Rule ID: 5712
Description: sshd: brute force trying to get access to the system. Non existent user.
Severity: Level 10 (High)
Rule Groups: authentication_failures, syslog, sshd
Detection Logic: Fires when 8 or more matching events (Rule 5710) occur from the same source IP within a 120-second window (frequency=8, timeframe=120, same_source_ip=true)
Related Rule: 5710 — sshd: Attempt to login using a non-existent user (individual event, Level 5)

3.2 Compliance Mapping

Framework	Control(s)
GDPR	IV_35.7.d, IV_32.2 — security of processing / risk assessment
HIPAA	164.312.b — audit controls
TSC (SOC 2)	CC6.1, CC6.8, CC7.2, CC7.3 — logical access & system monitoring

3.3 MITRE ATT&CK Mapping

- Technique: T1110 — Brute Force
- Tactic: Credential Access
- Sub-technique alignment: T1110.001 (Password Guessing) — repeated authentication attempts against a single account with no account lockout observed

3.4 Triage Assessment

True Positive. The activity matches the expected signature of a credential-guessing attack: rapid, repeated authentication failures against a non-existent/invalid account from a single source, escalating past the platform's correlation threshold. In a production environment, this pattern warrants immediate investigation of the source IP, and — if external — network-level blocking in addition to host-based response.

4. Secondary Finding: File Integrity Monitoring Coverage Gap

During testing, two files were deliberately created in directories commonly targeted by attackers for persistence or payload staging: `/etc/malicious_test_file.txt` and `/root/suspicious_script.sh`. No File Integrity Monitoring (FIM/syscheck) alerts were generated for either file.

4.1 Root Cause

Wazuh's default syscheck configuration does not include `/etc` or `/root` in its monitored path list on this build, and/or the scan interval had not yet elapsed at the time of testing (Wazuh FIM performs scheduled, not purely real-time, scans by default).

4.2 Risk Assessment

This represents a real and common production gap: default configurations frequently under-cover high-value directories. An attacker dropping a persistence script or web shell in an unmonitored path would go undetected by FIM until the next scheduled full scan, if at all.

4.3 Recommendation

- Explicitly add `/etc`, `/root`, and `/home/*/.ssh` to the `<syscheck>` monitored directories in `ossec.conf`
- Reduce the scan interval for high-value paths or enable real-time (inotify-based) monitoring where supported
- Periodically audit syscheck coverage against the organization's crown-jewel asset list

5. Response Actions Taken

5.1 Active Response Configuration

An active response rule was configured on the Wazuh manager to automatically invoke firewall-drop against the source IP for 300 seconds upon any Rule 5712 (brute-force) detection:

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5712</rules_id>
  <timeout>300</timeout>
</active-response>
```

Validation status: the manager successfully loaded the configuration and confirmed a live connection to the active-response dispatch queue (`queue/alerts/ar`). End-to-end command execution on the endpoint (iptables DROP rule insertion) was not observed during testing. This points to an agent-side synchronization or permissions gap between the manager's dispatch and the endpoint's `wazuh-execd` process — a known class of issue in distributed active-response deployments that typically requires verifying agent registration keys, remote command permissions, and `execd` connectivity.

Next steps identified: re-verify agent key registration, confirm `wazuh-execd` remote command permissions on the endpoint, and test with a manually triggered active-response command (`agent_control -f`) to isolate whether the gap is in rule dispatch or command execution.

6. Recommendations

- Implement account lockout or rate-limiting (e.g., fail2ban) on SSH to reduce the attack window before manual/automated response can act.
- Move to key-based SSH authentication only, disabling password authentication entirely.
- Expand FIM coverage to include /etc, /root, and SSH configuration/key directories.
- Complete active-response validation to enable automated containment for high-confidence detections.
- Establish a baseline alert-tuning review cadence to reduce noise from low-severity individual failed-login events (Rule 5710) while preserving visibility into the correlated brute-force signal.

7. Lessons Learned

This exercise validated that a correctly tuned SIEM/EDR platform can reliably detect brute-force credential attacks and correlate low-severity individual events into a high-confidence, actionable alert. It also surfaced two realistic operational gaps — incomplete FIM directory coverage and incomplete active-response execution — that mirror the kind of tuning and validation work expected of a SOC analyst in a production environment. Detection alone is not sufficient; verifying that response actions execute end-to-end is equally critical.

8. Appendix: Environment Details

Component	Detail
SIEM/EDR Platform	Wazuh 4.9.2 (Manager + Indexer + Dashboard)
Manager Host	Wazuh-Manager — Ubuntu 26.04 LTS — 10.0.2.3
Monitored Endpoint	Endpoint-01 — Ubuntu 26.04 LTS — 10.0.2.4
Network	VirtualBox NAT Network (isolated lab)
Total Events Captured	99 (24-hour window)
Primary Detection Rule	5712 — Level 10